Response to Reviewer 1

Enhancing Consent Policy Privacy in Blockchain-Based Healthcare Data Sharing

---

Working draft. The response text is complete for Comments 1 and 2. Page and line references will be added after the revised manuscript reaches final pagination.

Comments 1: *The security implications of the unbound program length should be more strongly addressed. According to the manuscript, the preimage of the commitment does not include the length of the program ℓ. Thus, a TPS that deviates from the prescribed workflow may consider a stack-consistent prefix of the committed token array instead of the full desired policy. This is not an implementation detail, but a matter of soundness. The proposed framework is oriented toward verifiable consent enforcement and therefore the authors should either bind the program length in the commitment/proof relation in the current implementation or give a much stronger justification for postponing this modification.*

Response 1: We thank the reviewer for identifying this soundness issue. We agree and have bound the program length in the commitment and proof relation in the current implementation.

In the submitted construction, the program length ℓ was used by the interpreter but was not bound to the policy commitment. A deviating TPS that knew the commitment opening could therefore attempt to evaluate a stack-consistent prefix under the commitment to the full padded token array. This can reverse an authorization outcome: for a requester satisfying A, the committed RPN program $[A, \mathrm{NOT}]$ with $\ell = 2$ denies, whereas the prefix $[A]$ with $\ell = 1$ grants.

The revised construction is

$$\begin{aligned} q &= H_{\mathrm{pol}}(P_{\mathrm{enc}}), \\ h &= \mathsf{Com}(P_{\mathrm{enc}}, \ell; r) = \mathsf{Poseidon}(q \parallel \ell \parallel r), \end{aligned}$$

where H_{pol} is the circuit's fixed-length Poseidon aggregation. The same private ℓ is supplied to both the commitment verifier and the RPN interpreter. Consequently, evaluating a different prefix would require opening h to a different (P_{enc}, ℓ) pair, which is excluded by the commitment's binding property under the collision resistance of Poseidon. The length remains private, and this modification adds no public proof input.

We added a dedicated regression suite as regression test that checks the following properties:

(i) the same padded token array and randomizer produce different commitments for different lengths;

(ii) a missing or out-of-range length is rejected;

(iii) the honest $[A, \mathrm{NOT}]$ program denies when $A = 1$;

(iv) its prefix authorizes when separately committed at length one, providing a positive control; and

(v) the truncated length cannot authorize under the commitment to the full program.

All seven regression tests pass.

The isolated circuit change adds 21 non-linear and 67 linear constraints, or 88 constraints in total (approximately 0.12% relative to the submitted 75,097-constraint circuit), and adds no public input. Thus, binding ℓ neither reveals the program length nor changes the policy-independent verification interface. Existing commitments and proving/verification keys from the submitted relation are incompatible with the revised relation and were regenerated.

Changes in the manuscript. The construction is now defined directly in the Design section, its integrity implication is distinguished from the metadata-privacy evaluation in the Discussion, and the former statement that program-length binding remained future work has been removed from the Conclusion.

Location in the revised manuscript: Section "TPS-ZKPI Design," subsection "Commitment Binding and Proof Generation."

> To bind each proof to a provider-defined hidden policy, the provider samples commitment randomness r uniformly from the scalar field and computes
>
> $$q = \mathsf{H}_{\mathrm{pol}}(P_{\mathrm{enc}}),$$
> $$h = \mathsf{Com}(P_{\mathrm{enc}}, \ell; r) = \mathsf{Poseidon}(q \parallel \ell \parallel r).$$
>
> Here, q is the Poseidon-based digest of the fixed-length encoded policy, ℓ is the private program length, r is the commitment randomness, and h is the policy commitment stored on-chain. The semantics of an encoded policy are determined by the pair (P_{enc}, ℓ), since ℓ identifies the active prefix of the padded token array. Accordingly, the circuit supplies the same private value ℓ to both the commitment verifier and the policy interpreter. Under the collision resistance of Poseidon, an accepting proof bound to h cannot substitute a different program length and therefore cannot evaluate an alternative stack-consistent prefix of P_{enc}.

Location in the revised manuscript: Section "Discussion."

> As described in the Design section, the policy commitment covers both the padded encoding P_{enc} and its active length ℓ. Because ℓ also determines how many tokens the interpreter evaluates, an authorizing proof for h cannot be based on a shorter valid prefix. This integrity guarantee is separate from our privacy evaluation, which measures whether public-chain artifacts reveal information about the hidden policy.

Comments 2: *The proof must be cryptographically linked to the authorization context. The current proof statement is not linked to the requester identity, protected resource, or session context. As mentioned in the manuscript, single-use of the nonce does not allow reuse of the same session parameters, but it does not prevent replay of a valid proof captured by an active party using fresh parameters. This is a significant limitation of the authorization guarantees of the current prototype. The authors would ideally add the relevant requester/resource/session values to the proved statement and experimentally evaluate the resulting circuit/public-input and gas cost changes. If this cannot be implemented in the current version, the security claims and deployment implications should be made even more explicit throughout the manuscript, including the abstract and conclusion.*

Response 2: We thank the reviewer for identifying this authorization-context gap. We agree and have implemented the proposed binding in both the circuit and the on-chain access-control path.

In the submitted system, the public statement contained the authorization output, policy commitment, and parameter commitment, but no value derived from the requester, resource, or session. The contract checked nonce reuse only from the transaction parameters. Consequently, a captured proof could be paired with a fresh nonce or another resource while the proof itself remained unchanged.

For the revised construction, let

$$\chi = (id_{\text{req}}, id_{\text{res}}, \nu), \qquad d_\chi = \mathsf{Poseidon}(id_{\text{req}} \parallel id_{\text{res}} \parallel \nu),$$

where ν is the session nonce. The circuit takes the three components of χ as private circuit inputs and enforces the hard equality $d_\chi = \mathsf{Poseidon}(\chi)$, with d_χ exposed as a public input. The ACM receives the same three values as transaction parameters, recomputes the digest on-chain, and requires it to equal the proof's public signal before verification. It also checks the resource–policy association, the public request epoch, and nonce single-use for the tuple $(\mathit{policy}, \mathit{resource}, \nu, id_{\text{req}})$. Thus, within one ACM deployment, changing the requester identifier, resource, or nonce causes rejection.

The three context values are private with respect to the Groth16 relation but are not hidden from the blockchain: they are present in transaction calldata so that the ACM can recompute the digest. We therefore describe id_{req} as a requester identifier or pseudonym, not as a hidden or universally authenticated real-world identity. The current statement contains five signals:

$$(1, h, pp, d_\chi, \tau),$$

namely one output and four public inputs; τ is a separate request-epoch input added for temporal policy checks.

We measured the context-binding change in isolation against the length-bound circuit immediately preceding it. It adds 605 R1CS constraints, increasing the total from 75,185 to 75,790 (0.8%), and adds one public input.

The revised implementation is covered at both layers. At the circuit layer, the test rejects a context digest computed for another nonce. At the contract layer, the tests confirm agreement between the circuit-side and EVM Poseidon implementations and reject substitutions of the requester, resource, and nonce. The end-to-end suite reuses one valid proof as a negative control and confirms that a fresh nonce or another resource governed by the same policy fails with a context-binding mismatch. All targeted tests pass.

We have kept the claim precise: the change closes the reviewer's fresh-parameter replay within one ACM deployment. The digest does not currently include the transaction submitter or a chain/contract domain, so the revised Discussion identifies exact-context front-running and cross-deployment reuse as separate hardening considerations.

Changes in the manuscript. The Design section now defines the context digest and the five-signal statement, explains the circuit and ACM checks, and removes the former future-work language. The Problem and Threat Model section now states explicitly that the SNARK does not authenticate attribute provenance or real-world attributes, distinguishes the pseudonymous requester identifier from real-world identity, and identifies adaptive requester probing and off-chain side channels as outside the present evaluation. The Discussion reports the measured marginal cost and states the scope of the resulting guarantee. The cost profile now reports the final RC1 circuit and public interface together with the revised Polygon Amoy gas, calldata, and prover measurements.

Location in the revised manuscript: Section "Problem and Threat Model," subsection "System and Trust Model."

The current model does not provide cryptographic protection against a compromised TPS. The SNARK establishes that the supplied witness satisfies the implemented policy relation, but it does not prove that each private attribute originates from an authenticated external source or corresponds to the requester's real-world attributes. Some policy types bind the pseudonymous requester identifier to a holder secret, but this is distinct from issuer-authenticated attribute provenance. Attribute-origin authenticity therefore remains outside the proved relation in the current implementation.

Location in the revised manuscript: Section "Problem and Threat Model," subsection "Public-Chain Adversary."

Adaptive requester probing and off-chain side channels are outside the scope of the present evaluation. The proved authorization outcome is bound to a pseudonymous requester identifier, a protected resource, and a session nonce through the context digest defined in the Design section. This binding prevents substitution of the recorded authorization context, but it should not be interpreted as proof of the requester's real-world identity.

Location in the revised manuscript: Section "TPS-ZKPI Design," subsection "Commitment Binding and Proof Generation."

For an access request, let

$$\chi = (id_{\text{req}}, id_{\text{res}}, \nu), \qquad d_\chi = \mathsf{Poseidon}(id_{\text{req}} \parallel id_{\text{res}} \parallel \nu),$$

where ν is a fresh session nonce. The TPS constructs the private circuit witness

$$w = (P_{\text{enc}}, \ell, a, b, r, \omega, \chi).$$

The context tuple χ consists of private circuit inputs, while its digest d_χ is public. The current public-signal vector is

$$(1, h, pp, d_\chi, \tau),$$

where pp is a fixed-format commitment to the per-predicate parameters and τ is the request epoch used by the temporal checks. Although the three components of χ are not separate Groth16 public inputs, the ACM receives them as transaction parameters in order to recompute d_χ; they are therefore visible in transaction calldata. The TPS generates a proof

$$\pi \leftarrow \mathsf{Prove}(pk, w; (1, h, pp, d_\chi, \tau)).$$

The proof certifies the conjunction that $C(P_{\text{enc}}, \ell, (a, b)) = 1$, $h = \mathsf{Com}(P_{\text{enc}}, \ell; r)$, $d_\chi = \mathsf{Poseidon}(\chi)$, and required external-predicate checks are internally consistent with respect to the supplied parameters and placeholder gadgets. Before verifying π, the ACM checks that the resource is governed by the stated policy, that τ is current, that the nonce has not been used for the same requester–resource context, and that the digest recomputed from the transaction parameters equals the public signal d_χ. Thus, within one ACM deployment, a proof generated for one requester identifier, resource, and nonce cannot be accepted under a different tuple.

Location in the revised manuscript: Section "Discussion."

The circuit constrains the public digest d_χ to the requester identifier, resource, and nonce used in the witness, and the ACM recomputes the same digest from the transaction parameters. Consequently, changing any of these values invalidates the request.

Location in the revised manuscript: Section “Evaluation,” cost profile table.

Circuit size: 81,740 R1CS constraints and 80,884 wires at DEPTH = 64. Public interface: four public inputs plus one output. Across the 1,773 revised Polygon Amoy executions, mean padded gas is 304,167 for commit and 1,057,283 for access; the fixed calldata lengths are 196 and 612 bytes, respectively.